

GetPDF Lab[惡意軟體分析](wireshark、pdf)

PDF 格式是線上交換文件的實際標準。然而，這種流行也吸引了網路犯罪分子，他們向毫無戒心的用戶傳播惡意軟體。許多漏洞利用工具包都內建了產生惡意 PDF 檔案來分發惡意軟體的功能。由於使用者在開啟 PDF 檔案時不太謹慎，惡意 PDF 檔案已成為相當成功的攻擊媒介。lala.pcap 捕獲的網路流量包含與典型惡意 PDF 檔案攻擊相關的網路流量，在這種攻擊中，毫無戒心的使用者開啟一個受感染的網頁，該網頁會將使用者的網頁瀏覽器重定向到惡意 PDF 檔案的 URL。當瀏覽器的 PDF 外掛程式開啟 PDF 時，未修補的 Adobe Acrobat Reader 版本會被利用，從而下載並在使用者的電腦上靜默安裝惡意軟體。

作為社會分析師，分析 PDF 並回答問題。

支持資源：

PDF格式結構:<https://resources.infosecinstitute.com/topic/pdf-file-format-basic-structure/>

便攜式文件格

式:https://web.archive.org/web/20220113130243/https://www.adobe.com/content/dam/acom/en/devnet/pdf/pdfs/PDF32000_2008.pdf

官方建議Tools:

de4js

pdfid

pdfparser

peepdf

PDFStreamDumper

Wireshark

tshark

scdbg

NetworkMiner

問題 1

此事件涉及多少個 URL 路徑？

lala.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http contains "GET"

No.	Time	Source	Destination	Protocol	Length	Info
6	2010-10-07 11:58:03.981648	172.16.201.128	202.190.85.44	HTTP	446	GET /forensic_challenge HTTP/1.1
9	2010-10-07 11:58:04.003820	172.16.201.128	202.190.85.44	HTTP	447	GET /forensic_challenge/ HTTP/1.1
14	2010-10-07 11:58:04.033634	172.16.201.128	202.190.85.44	HTTP	515	GET /forensic_challenge/getpdf.php HTTP/1.1
17	2010-10-07 11:58:04.054335	172.16.201.128	202.190.85.44	HTTP	518	GET /forensic_challenge/fcexploit.pdf HTTP/1.1
49	2010-10-07 11:58:04.901016	172.16.201.128	202.190.85.44	HTTP	409	GET /favicon.ico HTTP/1.1
57	2010-10-07 11:58:05.609157	172.16.201.128	202.190.85.44	HTTP	305	GET /forensic_challenge/the_real_malware.exe HTTP/1.1
64	2010-10-07 11:58:07.105039	172.16.201.128	202.190.85.44	HTTP	439	GET /favicon.ico HTTP/1.1

Wireshark - HTTP / Requests - lala.pcap

Request Type	Count	Average	Min Val	Max Val	Rate (ms)	Percent	Burst Rate
HTTP Requests by HTTP Host	7				0.0022	100%	0.0400
blog.honeynet.org.my	7				0.0022	100.00%	0.0400
/forensic_challenge/the_real_malware.exe	1				0.0003	14.29%	0.0100
/forensic_challenge/getpdf.php	1				0.0003	14.29%	0.0100
/forensic_challenge/fcexploit.pdf	1				0.0003	14.29%	0.0100
/forensic_challenge/	1				0.0003	14.29%	0.0100
/forensic_challenge	1				0.0003	14.29%	0.0100
/favicon.ico	2				0.0006	28.57%	0.0100

6

第二季

包含 JS 程式碼的 URL 是什麼？

Wireshark - Follow HTTP Stream (tcp.stream eq 0) - lala.pcap

File Edit View Go

tcp.stream eq 0

No.	Time	Source	Destination	Protocol	Length	Info
3	2010-10-07 11:58:03.981648	172.16.201.128	202.190.85.44	HTTP	446	GET /forensic_challenge HTTP/1.1
4	2010-10-07 11:58:04.003820	172.16.201.128	202.190.85.44	HTTP	447	GET /forensic_challenge/ HTTP/1.1
5	2010-10-07 11:58:04.033634	172.16.201.128	202.190.85.44	HTTP	515	GET /forensic_challenge/getpdf.php HTTP/1.1
6	2010-10-07 11:58:04.054335	172.16.201.128	202.190.85.44	HTTP	518	GET /forensic_challenge/fcexploit.pdf HTTP/1.1
7	2010-10-07 11:58:04.901016	172.16.201.128	202.190.85.44	HTTP	409	GET /favicon.ico HTTP/1.1
8	2010-10-07 11:58:05.609157	172.16.201.128	202.190.85.44	HTTP	305	GET /forensic_challenge/the_real_malware.exe HTTP/1.1
9	2010-10-07 11:58:07.105039	172.16.201.128	202.190.85.44	HTTP	439	GET /favicon.ico HTTP/1.1

Frame 8: 794 bytes on wire (6352 bits) captured (0.000000000 seconds) on interface eth0

Ethernet II, Src: lala (08:00:00:00:00:00), Dst: 202.190.85.44 (08:00:00:00:00:00)

Internet Protocol Version 4, Src: 172.16.201.128, Dst: 202.190.85.44

Transmission Control Protocol, Src Port: 54321, Dst Port: 80, Seq: 301, Win: 64240, Len: 0

Hypertext Transfer Protocol

GET /forensic_challenge HTTP/1.1

Host: blog.honeynet.org.my

User-Agent: Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9.2.3) Gecko/20100401 Firefox/3.6.3

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Language: en-us,en;q=0.5

Accept-Encoding: gzip,deflate

Accept-Charset: ISO-8859-1,utf-8;q=0.7,*;q=0.7

Keep-Alive: 115

Connection: keep-alive

HTTP/1.1 301 Moved Permanently

Date: Thu, 07 Oct 2010 11:58:03 GMT

Server: Apache/2.2.14 (Ubuntu) PHP/5.3.2-1ubuntu4.2 with Suhosin-Patch proxy_html/3.0.1 mod_ssl/2.2.14 OpenSSL/0.9.8k

Location: http://blog.honeynet.org.my/forensic_challenge/

Vary: Accept-Encoding

Content-Encoding: gzip

Content-Length: 321

Keep-Alive: timeout=15, max=100

Connection: Keep-Alive

Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">

<html><head>

<title>301 Moved Permanently</title>

</head><body>

<h1>Moved Permanently</h1>

<p>The document has moved here.</p>

<hr>

<address>Apache/2.2.14 (Ubuntu) PHP/5.3.2-1ubuntu4.2 with Suhosin-Patch proxy_html/3.0.1 mod_ssl/2.2.14 OpenSSL/0.9.8k Server at blog.honeynet.org.my Port 80</address>

</body></html>

Packet 8, 6 client pkt(s), 6 server pkt(s), 11 turn(s). Click to select.

http://blog.honeynet.org.my/forensic_challenge/

第三季

JS程式碼裡隱藏的URL是什麼？

同上，往下滑：

The image shows a Wireshark packet capture of an HTTP stream. The packet list on the left shows a GET request for `/forensic_challenge/getpdf.php` at 14:10:07. The packet details pane on the right shows the request headers and body. The body contains a JavaScript payload that attempts to download a PDF file from `http://blog.honeynet.org.my/forensic_challenge/getpdf.php`.

```
GET /forensic_challenge/getpdf.php HTTP/1.1
Host: blog.honeynet.org.my
User-Agent: Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9.2.3) Gecko/20100401 Firefox/3.6.3
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Accept-Encoding: gzip,deflate
Accept-Charset: ISO-8859-1,utf-8;q=0.7,*;q=0.7
Keep-Alive: 115
Connection: keep-alive
Referer: http://blog.honeynet.org.my/forensic_challenge/
```

The packet bytes pane at the bottom shows the raw data of the request, including the URL `http://blog.honeynet.org.my/forensic_challenge/getpdf.php`.

第四季

封包中包含的 PDF 檔案的 MD5 雜湊值是多少？

匯出：

The image shows a Wireshark packet capture of an HTTP stream. The packet list on the left shows a GET request for `/forensic_challenge/getpdf.php` at 14:10:07. The packet details pane on the right shows the request headers and body. The body contains a JavaScript payload that attempts to download a PDF file from `http://blog.honeynet.org.my/forensic_challenge/getpdf.php`.

The packet bytes pane at the bottom shows the raw data of the request, including the URL `http://blog.honeynet.org.my/forensic_challenge/getpdf.php`.

Below the Wireshark capture, a terminal window shows the command `md5sum fcexploit.pdf` being executed, resulting in the MD5 hash `659cf4c6baa87b082227540047538c2a`.

問5

PDF 檔案內包含多少個物件？

```
(root@kali) ~# pdfid fcexploit.pdf
PDFiD 0.2.10 fcexploit.pdf
PDF Header: %PDF-1.3
obj 19
endobj 18
stream 5
endstream 5
xref 1
trailer 1
startxref 1
/Page 2
/Encrypt 0
/ObjStm 0
/JS 1
/JavaScript 1
/AA 0
/OpenAction 1
/AcroForm 1
/JBIG2Decode 0
/RichMedia 0
/Launch 0
/EmbeddedFile 1
/XFAETag: "b0035-6251149205
/Colors> 2^24
```

pdf-parser fcexploit.pdf --search /Filter | grep Filter

```
(root@kali)~[/home/kali/Desktop]
# pdf-parser fcexploit.pdf --search /Filter | grep Filter
/Filter [ /FlateDecode /ASCII85Decode /LZWDecode /RunLengthDecode ]
/Filter [ /FlateDecode /ASCII85Decode /LZWDecode /RunLengthDecode ]
/Filter [ /FlateDecode /ASCII85Decode /LZWDecode /RunLengthDecode ]
/Filter [ /FlateDecode /ASCII85Decode /LZWDecode /RunLengthDecode ]
```

4

相同物件有5、7、9、10

問7

可能包含惡意 JS 程式碼的「物件流」的數量是多少？

pdf-parser fcexploit.pdf

```
obj 4 0
Type: /Action
Referencing: 5 0 R
<<
  /Type /Action
  /S /JavaScript
  /JS 5 0 R
>>

obj 5 0
Type:
Referencing:
Contains stream
<<
  /Length 395
  /Filter [ /FlateDecode /ASCII85Decode /LZWDecode /RunLengthDecode ]
>>
```

5

問8

分析 PDF 檔案。哪些「物件流」包含負責執行 Shellcode 的 JS 程式碼？ JS 代碼被分成兩個流。格式：兩個數字，用“，”分隔。按升序排列。

答：

問9

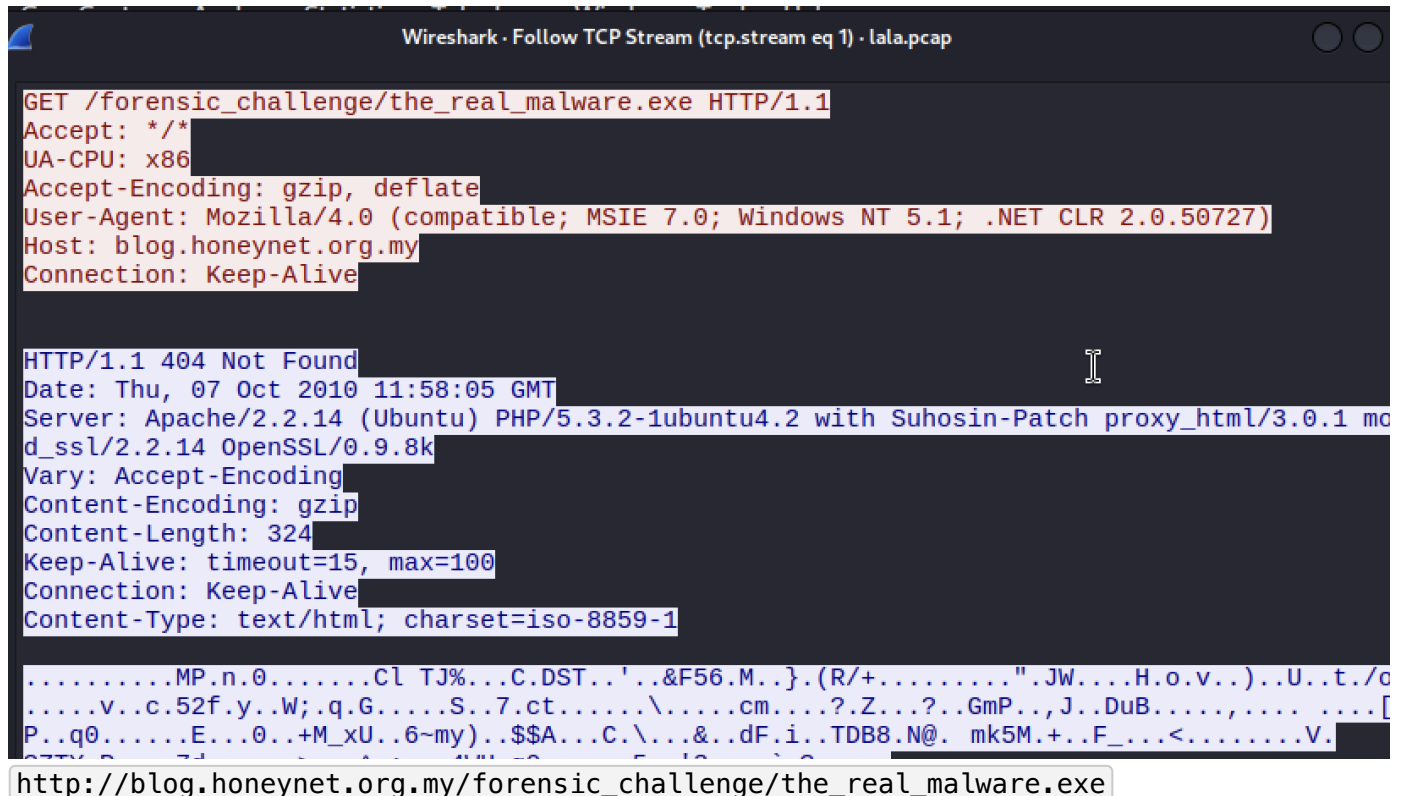
負責執行漏洞利用的 JS 程式碼包含釋放惡意可執行檔的 Shellcode。惡意軟體在受害者機器上釋放惡意可執行檔後，其完整路徑為何？

答：

Q10

PDF 檔案包含另一個與 CVE-2010-0188 相關的漏洞。與此漏洞相關的 Shellcode 釋放的惡意可執行檔的 URL 是什麼？

同3，的下一頁



```
Wireshark · Follow TCP Stream (tcp.stream eq 1) · lala.pcap

GET /forensic_challenge/the_real_malware.exe HTTP/1.1
Accept: */*
UA-CPU: x86
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 5.1; .NET CLR 2.0.50727)
Host: blog.honeynet.org.my
Connection: Keep-Alive

HTTP/1.1 404 Not Found
Date: Thu, 07 Oct 2010 11:58:05 GMT
Server: Apache/2.2.14 (Ubuntu) PHP/5.3.2-1ubuntu4.2 with Suhosin-Patch proxy_html/3.0.1 mod_ssl/2.2.14 OpenSSL/0.9.8k
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 324
Keep-Alive: timeout=15, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=iso-8859-1

.....MP.n.0.....Cl TJ%...C.DST..'..&F56.M..}..(R/+.....".JW....H.o.v...)..U..t./o
.....v..c.52f.y..W;.q.G.....S..7.ct.....\.....cm.....?..Z...?..GmP..,J..DuB.....[
P..q0.....E...0...+M_xU..6~my)..$$A...C.\...&...dF.i..TDB8.N@. mk5M.+..F_...<.....V.
http://blog.honeynet.org.my/forensic_challenge/the_real_malware.exe
```

問11

PDF 檔案中包含多少個 CVE？

答：